codigo

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Análise passo a passo do arquivo `codigo.py` para determinar sua natureza:

Análise Passo a Passo

1. Comando e Controle Descentralizado via Blockchain (Solana)

O que faz: As funções `_getSignFAddress` e `fvzsrnzlh` consultam publicamente nós da rede blockchain **Solana** em busca de transações direcionadas a uma carteira específica (`BjVeAjPrSKFiingBn4vZvghsGj9KCE8AJVtbc9S8o8SC`). O script extrai dados do campo *memo* dessas transações e os converte em JSON para obter links de comando e controle (C2).

Propósito malicioso: O uso de blockchains públicas como canal de C2 é uma técnica avançada de evasão. Como a infraestrutura é descentralizada, é extremamente difícil para autoridades ou ferramentas de segurança derrubar ou bloquear os endereços de controle tradicionais baseados em DNS.

2. Evasão por Geolocalização e Idioma (*Geofencing* Antirrusso)

O que faz: A função `_isRussianSystem` verifica variáveis de ambiente (`LANG` , `LC_ALL` , `USERNAME`), o local do sistema, o fuso horário e o deslocamento UTC para identificar se o computador alvo está localizado na Rússia ou utiliza o idioma russo. Se a condição for verdadeira, o script encerra a execução imediatamente (`skipping execution`).

Propósito malicioso: Este comportamento é amplamente conhecido em malwares de origem russa ou da Comunidade de Estados Independentes (CEI). Os operadores evitam infectar computadores em seus países de origem para reduzir o risco de investigações e ações de agências de aplicação da lei locais.

3. Gerenciamento de Estado e Persistência (`init.json`)

O que faz: O script cria e manipula um arquivo chamado `init.json` no diretório raiz do usuário (`~`), registrando carimbos de data/hora (`timestamp`) para controlar a frequência de execução e evitar requisições repetitivas ou desnecessárias em execuções sucessivas.

4. Download Silencioso do Ambiente Node.js

O que faz: A função `download_nodejs` identifica automaticamente o sistema operacional (Windows, macOS ou Linux) e a arquitetura da máquina (x64, ARM64, etc.), baixando uma versão portátil oficial do **Node.js (v22.9.0)** diretamente para a pasta do usuário, extraindo-a sem necessidade de privilégios de administrador.

Propósito malicioso: Garante que o ambiente de execução necessário para rodar o payload secundário esteja presente na máquina vítima, independentemente de o usuário ter o Node.js instalado ou não.

5. Execução de Carga Oculta (Payload via JavaScript e `eval`)

O que faz: Através da função `scyzzvvy` , o script baixa um payload remoto via HTTP, lê segredos e vetores de inicialização ocultos nos cabeçalhos da resposta HTTP, cria um arquivo temporário em JavaScript (`i.js`), e executa o código usando `eval(atob(...))` (descodificando strings em Base64). Tudo isso é executado em segundo plano de forma oculta (`subprocess.Popen` com janelas ocultas no Windows e sem exibir logs no console).

Conclusão Final

Este arquivo é um MALWARE.

Trata-se de um **dropper / loader altamente sofisticado** projetado para:

1. Escapar de análises comportamentais e detecções tradicionais de antivírus por meio de geofencing.
2. Utilizar a blockchain Solana como um canal de C2 resiliente e imune a quedas de domínio.
3. Preparar o ambiente da vítima baixando interpretadores externos (`Node.js`) de forma silenciosa.
4. Baixar, decodificar e executar cargas maliciosas arbitrárias em segundo plano na máquina infectada.

Qual é a categoria principal deste malware?

A categoria principal deste malware é a de **Dropper** (ou **Loader** / **Carregador**).

Justificativa:

Embora o script execute várias técnicas avançadas de segurança e evasão (como a verificação de geolocalização, persistência e comunicação descentralizada via blockchain Solana), a sua função principal não é realizar diretamente o dano final (como o roubo de credenciais, encriptação de ficheiros ou mineração de criptomoedas).

Em vez disso, ele atua como um vetor de preparação e entrega:

1. **Prepara o ambiente:** Descarrega e instala de forma silenciosa e autónoma um interpretador externo (**Node.js**) na máquina da vítima.
2. **Obtém o payload:** Consulta a rede Solana e servidores externos para obter o código malicioso real.
3. **Executa o verdadeiro malware:** Descodifica e executa o código secundário (em JavaScript) de forma oculta no sistema.